

Security Now! #1092 - 08-18-26

Restraint Abliteration

This week on Security Now!

- Trusting an open source AI proxy might bite you.
- France's under-15 social media ban hits its constitution.
- A bit of AI prompting found a serious bug in Zoom.
- AI-based network defenders see a stock price jump.
- A (very) deep dive into the operation of AI chatbots.

**This actually happened in Albania. Was it an accident?
Or a VERY clever way to create a bridge across the river?**



<https://albaniandailynews.com/news/tirana-prosecution-launches-probe-into-city-bus-ending-up-in-lana-river-1>

Security News

As I promised last week, there are two very important pieces of core AI technology I want to discuss today. I also promised that we'd be doing a deep dive into aspects of the operation of today's AI. That turned out to be more true than I expected, so much so that it entirely crowded out the second topic I had planned to get into. But fear not, we'll have another deep dive into that second topic next week. So, let's start by covering some important recent security events:

Terabytes of credentials leaked in massive supply-chain attack

Last Wednesday, ArsTechnica's Dan Goodin reported under the headline *"Terabytes of credentials leaked in massive supply-chain attack."* That headline was the kind of thing I would have chosen to share a few years ago. But the thing that raised my interest another several notches was the article's tagline which read: *"The data was scraped and exfiltrated from 2,500 users of a compromised AI package."* Whoa! And we're not talking about some random end users no one knows, here. Wait 'til you hear **whose** credentials were among the more than 2,500 that were stolen. Dan writes:

Terabytes worth of credentials, many belonging to the world's biggest and most sensitive organizations, have been exposed in a supply-chain attack on LiteLLM, an open source tool that streamlines AI-driven software development. Microsoft, Amazon, Cisco, Samsung, and Salesforce are only a handful of the entities whose access secrets were exposed.

The revelation was posted on Tuesday and Wednesday by security firms CloudSEK and Hudson Rock. CloudSEK said it found cloud keys, repository tokens, SSH keys, Kubernetes secrets, package publishing credentials, environment variables, and AI provider keys that could allow attackers to gain access to more than 2,500 organizations. And 40 minutes is all it took.

The credentials were extracted during a 40-minute window in March while the victims used compromised versions of LiteLLM downloaded from the package's official location in the Python Package Index repository. Hudson Rock said it made the discovery after analyzing a 195 terabyte file that it obtained. Neither firm identified the source of the information.

The LiteLLM compromise was the result of a previous supply-chain attack that infected the widely used vulnerability scanner Trivy. Other software infected in the campaign includes KICS and the Telnyx Python SDK. TeamPCP, a ramshackle but extremely capable gang largely made up of teenagers, took credit for the attack, and researchers have largely corroborated the claim.

Independent security researcher Kevin Beaumont said: "I've confirmed the data is legit, by the way, multiple victim orgs. It contains a significant volume of sensitive content at orgs. It's a massive supply chain breach due to poor AI security—not because AI is the threat, but teens can run circles around orgs obsessed with rushing out AI and poor DevOps security."

The compromised versions of all four software packages contained code that accessed the memory of infected machines, scraped its contents, and exfiltrated it through an attacker-controlled channel. The data is filled with an assortment of information. Interspersed in the wall of data are credentials to software pipelines maintained by the tens of thousands of organizations that ran LiteLLM during the 40-minute span that the supply-chain attack remained active.

In all, both security firms said some 434,000 CI/CD (continuous integration/continuous

delivery) software pipelines had credentials exposed after running the compromised LiteLLM versions. In many cases, researchers at CloudSEK and Hudson Rock had trouble identifying the organizations the credentials belonged to. For instance, an email address in the dump from the domain @siriusxm.com ultimately didn't indicate a breach at the satellite broadcaster, but rather one within the infrastructure of SiriusXM subsidiary AdsWizz. A trove of internal corporate secrets were found exposing sensitive tokens for platforms such as Salesforce (SALESFORCE_CLIENT_SECRET), Slack (SLACK_SIGNING_SECRET), and Microsoft Azure environments. The researchers had high confidence that the following organizations had their credentials exposed:

Nvidia Corporation, Amazon Web Services (AWS), Samsung Electronics, [samsung.com](https://www.samsung.com), Salesforce, Inc., Cisco Systems, Inc., F. Hoffmann-La Roche AG, ServiceNow, Siemens AG, S&P Global, Airbus US Space & Defense, John Deere, Regeneron Pharmaceuticals, Inc., London Stock Exchange Group (LSEG), Thomson Reuters, FedEx, MediaTek Inc., Volkswagen AG, Deloitte, The Kroger Co., Siemens Energy, Thales Group, X Corp (Twitter), Zscaler, Inc., Epic Games, Orange S.A., HP Inc., Philips, Vodafone Group Plc, Carl Zeiss AG, Deutsche Bahn AG, NGINX, Inc., BT Group, and Roku, Inc.

Hudson Rock said: "Many CI/CD pipelines are configured generically. The dumped variables contain active database passwords, third-party API keys, and cloud credentials without any identifiable company email, custom domain string, or internal server name. This means that countless organizations [which we were unable to identify] currently have active secrets sitting in this database. They are completely unaware of their exposure."

Under the heading: "Welcome to the new world of supply-chain attacks" Dan then adds:

Both firms are urging all organizations that used the compromised versions of LiteLLM — particularly those listed in the high-confidence section of the list — to thoroughly rotate all credentials in their pipelines. Hudson Rock instructed any organization that uses any AI proxy infrastructure, third-party CI/CD vulnerability scanners, or downstream AI packages to immediately audit their environment for versions 1.82.7 and 1.82.8 of LiteLLM, which were the two compromised versions of the software.

The firm advised all those affected to perform "aggressive credential revocation," assume any secret accessible to the LiteLLM environment is compromised, invalidate and rotate all cloud keys, Kubernetes service account tokens, and GitLab/GitHub PATs, and audit logging and egress filtering.

As a cautionary tale, CloudSEK said that Trivy developers rotated but failed to fully revoke an automation token over a 20-day window. The lapse gave the attackers a nearly three-week period to force-push malicious code to third-party builds that used the vulnerability scanner. As Beaumont observed, organizations' rush to integrate AI into their software delivery systems has also greatly contributed to the scale of the damage.

And then, in an update to his initial reporting of this massive mess, Dan adds:

Update: There are already signs that some of the affected organizations are not taking the disclosure with the seriousness warranted. After this post went live, Kevin Beaumont reported:

*These creds date from about March. One of the orgs impacted told me they'd rotated them all and it's a nothingburger, so I looked at their responsible disclosure policy, it allows trying creds, so I tried them all. **Almost every one of them worked.** I submitted a report. One of the biggest US techcos.*

Ultimately, the new revelations concerning the LiteLLM supply-chain attack underscore the growing threat of such campaigns and hence the importance of maintaining vigilance around the use of open source software that, when infected, can spread rapidly across the Internet.

Alon Gal, co-founder and chief technology officer of Hudson Rock, wrote in an email: "The key takeaway is how supply chains have evolved to make a single upstream breach affect thousands of companies simultaneously. A window of roughly 40 minutes in which the LiteLLM dependency was hacked led to over 430,000 instances in which millions of secrets were harvested. This magnitude pushes us into a completely new world regarding the type of response required from the cybersecurity industry."

Just to be clear, the cautionary takeaway from this is not a case of AI going rogue or AI misuse. I followed Dan's reference links back to one of Hudson Rock whose much more technical write-up of the breach makes what actually happened clear. Hudson Rock's headline was "**Largest AI Supply Chain Breach of 2026: LiteLLM Hack Impacts Thousands of Global Enterprises**" and they explain:

The cybersecurity landscape is currently reeling from one of the most sophisticated multi-ecosystem supply chain campaigns publicly documented to date. Orchestrated by a threat actor group known as "TeamPCP," this cascading attack ultimately compromised LiteLLM – a widely adopted open-source AI proxy gateway – leading to the silent exfiltration of deep developmental secrets from thousands of continuous integration and continuous deployment (CI/CD) pipelines worldwide.

*Excellent forensic research published by Snyk, Trend Micro, and Cocode has thoroughly detailed the mechanics of this breach. The attack did not begin with LiteLLM. Instead, TeamPCP first compromised the GitHub Actions pipeline for Trivy, a highly popular open-source vulnerability scanner. Because the developers of LiteLLM utilized Trivy in their own CI/CD pipeline, the poisoned security scanner was granted legitimate read access to their runner environment. This allowed the attackers to silently exfiltrate LiteLLM's PyPI publishing tokens. Armed with these credentials, TeamPCP was able to publish malicious **versions** of the LiteLLM package (v1.82.7 and v1.82.8).*

The payload delivery was exceptionally stealthy. By utilizing a .pth Python startup hook, the malicious code executed the moment the Python interpreter initialized – regardless of whether the LiteLLM library was explicitly imported. The three-stage payload immediately began harvesting environment variables, local configuration files (like .kube/config and .aws/credentials), attempted lateral movement across Kubernetes clusters, and installed a persistent systemd backdoor.

While the security community has deeply analyzed the malware's behavior, Hudson Rock has independently obtained the actual fallout: the raw exfiltrated data. This provides an unfiltered look into the massive scale of the compromise through the actual, raw files.

Our researchers have obtained and analyzed a staggering 153GB RAR archive. This massive corpus contains exactly 433,909 files. Through our analysis, we have successfully attributed 118,829 CI runner dumps to 2,488 affected corporate domains. Whenever a developer machine, production server, or CI/CD pipeline executed the compromised LiteLLM package, the threat actors successfully harvested the live environment memory and configurations mid-execution.

So the real takeaway from this is that the massive adoption of the automation of development and delivery will tend to coalesce around relatively few popular best-of-class tools. This naturally makes those tools a highly valuable target for attackers. Over at Github, the LiteLLM repository describes itself, writing:

LiteLLM is an open source AI Gateway that gives you a single, unified interface to call 100+ LLM providers — OpenAI, Anthropic, Gemini, Bedrock, Azure, and more — all using the OpenAI format. Use it as a Python SDK for direct library integration, or deploy the AI Gateway (Proxy Server) as a centralized service for your team or organization.

Managing LLM calls across providers gets complicated fast — different SDKs, auth patterns, request formats, and error types for every model. LiteLLM removes that friction with a:

- *Unified API — one interface for 100+ LLMs, no provider-specific SDK juggling*
- *Drop-in OpenAI compatibility — swap providers without rewriting your code*
- *Production-ready gateway — virtual keys, spend tracking, guardrails, load balancing, and an admin dashboard out of the box*
- *8ms P95 latency at 1k RPS (benchmarks)*

Sounds great, right? The only glitch here is that it must be totally trustworthy. In order for LiteLLM to be able to proxy all of those differing LLM backends, it must necessarily have every user's authentication credentials for every one of those different LLM backends.

So, what happened here is that the LiteLLM developers were users of the Trivy vulnerability scanner. As we know, because we talked about this many months ago, Trivy was compromised. This allowed attackers to compromise any project that was using Trivy as its scanner. And thus, in turn, those two versions of LiteLLM were compromised, giving attackers complete visibility into the credentials and domains of 2,488 corporate users of LiteLLM.

I always like to try to suggest solutions to the problems we encounter, but I got nothin' here.

We're now in a mode where everyone feels that they need to always be running the latest and greatest release of everything. We've done this to ourselves. I preach that relentlessly, right? The entire security community is constantly pressing everyone to be better about updating their software. Stay current. Be sure you're receiving announcements of important updates. Blah, blah, blah. But in this instance doing that is precisely what bit the users of those specific two versions of LiteLLM. If they had NOT updated to those; if they had remained on a previous release; then they would have never run one of those two malicious versions.

But that doesn't work as a strategy either. Who knows what might be malicious and what isn't. The only winning strategy — or at least the best available strategy for the moment — is to carefully monitor the news of the tools you're using. You need to stay current. But mistakes such as these will happen. The instant you learn of a breach that affects you, invalidate and recreate (in other words, rotate) all possibly-affected credentials. We've seen many instances where that was not done. Part of what made LastPass's troubles even greater was that even after they learned that they'd been breached they failed to fully cancel all previous authentication credentials. And as a perfect case in point, we learned that a major Telco did not actually rotate their credentials when they had claimed to.

So I guess I actually do have an important and practical takeaway from this: We know that things that are easily done, tend to be done, and things that are a confusing pain in the butt too often fall into the *"I'll get back to that later"* category. What we see is that with the speed of modern attackers, "later" stands a very good chance of not being soon enough. So here's my point: If there's really no practical means of preventing inadvertent exposure to credential-leaking malware, then rotating all of the credentials that any malware might have obtained, the moment a credential-compromising attack is known, is important. Moreover, periodically rotating credentials preemptively on the "better safe than sorry" principle can be useful when the threat environment warrants it. But, that means that whole-organization, organization-wide credential rotation needs to be both possible **and** easy. If it's not easy it won't happen or it will be put off. So my best advice would be, if you're looking for a nice self-contained and easy to describe project for an AI agent to tackle, a great investment would be to employ some AI to implement a comprehensive credential rotation facility for your organization. Make it a single command that handles everything. Make it easy, even fun to use, and use it to maintain the credentials for both current and new services as they are added and removed. REQUIRE its use for instantiating any new credential so that it cannot fall out of sync — or, again, it won't be trusted and used. So make it an integral part of the entire process.

France's top court blocks social media ban for under-15s

France's recently celebrated ban on social media access for all children younger than 15 hit a roadblock. Last Friday, Reuters reported the following:

France's top court on Friday blocked a bill banning social media access for under-15s, saying it infringed upon freedom of expression and delivering a setback for President Emmanuel Macron, who asked his government to rewrite the legislation. The bill would have barred children younger than 15 from opening a social media account from September 1st, and all accounts already open would be closed by year end, which would also need to use age verification approved by the French privacy regulator.

*But France's Constitutional Council found that the bill, while requiring **everyone** to give proof of age, failed "to specify the conditions and limits" under which it should be provided, as well as infringing on freedoms and privacy.*

In the context of domestic U.S. pornography legislation, we've noted that blocking **anything** for all users below a certain age inherently requires everyone's age to be known; there's no way around that. So France now needs to tackle the thorny problem of that inescapable infringement

upon the Internet's illusion of total freedom and privacy. I chose to phrase it that way because on the Internet, reality and belief are rarely aligned. There's never been a greater infringement upon privacy than the abuse of 3rd-party browser cookies. But since they largely went unseen, Internet users were allowed to imagine that no one was watching their actions or compiling extensive hidden dossiers of their habits. The problem with age assertion is that because it's explicit and cannot be similarly hidden, everyone is outraged. The truth is that if we want our governments to restrict children's access to Internet content then everyone's age must be known by someone, somewhere; either by every source of proscribed content or by every means of accessing such content. Reuters continues, quoting the Constitutional Council's statement:

"The Council holds that the contested provisions, on the one hand, disproportionately infringe upon the freedom of expression and communication and, on the other, fail to provide the legal safeguards necessary to ensure the right to respect for private life."

French lawmakers had approved the bill in July, becoming the first in Europe to follow Australia, whose world-first ban barred access to platforms including Facebook, Snapchat, TikTok and YouTube for under-16s in December. Lawmakers there are considering stricter penalties after data showed mixed success. Countries around the globe, including China, the United Arab Emirates and Turkey, have either instituted measures intended to curtail or bar access to social media for young people, or have said they were planning them. The European Union has said it was planning to seek stronger protections for children from harmful social media features.

Social media companies generally oppose blanket bans, saying they have measures already in place to protect younger users, including age restrictions, though they have also said they would comply with government bans. Google, Meta, Snap and TikTok did not immediately respond to requests for comment.

Macron, who in April urged teenagers to turn off their devices and read in order to become better citizens, has ordered Prime Minister Sebastien Lecornu to rework the draft legislation to take the Constitutional Council's concerns into account, the Elysee said in a statement. The Elysee said Macron was determined for the reform to take effect before spring 2027, when France holds a presidential election. Macron cannot run for a third term.

So, President Macron has not given up. The draft legislation is being hastily reworked to address the Council's concerns since Macron still hopes to have this reform in effect as soon as possible. Reuter's report did not make any mention of the smartphone restriction aspect of the legislation which Macron wanted to have in place before the start of this school year. The existing primary school restriction was being extended through high school.

AI used to discover a serious Zoom vulnerability

Last Tuesday, WIRED reported on the unnerving discovery of a serious vulnerability in the Zoom teleconferencing system. WIRED's headline was: *"A Zoom Screen-Sharing Bug Let Anyone Take Over Other Devices on a Call"* and their brief teaser that makes this so interesting is:

"Researchers say it took fewer than 20 prompts for a public AI tool to find a flaw (now fixed) allowing anyone on a Zoom call to hijack another participants' device." Here's the story:

As AI models gain advanced capabilities to find vulnerabilities in software, develop ways to exploit them, and even carry out autonomous hacking sprees, researchers offered a sobering new example on Tuesday, disclosing vulnerabilities in the video conferencing platform Zoom that could have been exploited to take over targets' devices. Anyone on a call that involved screen sharing, whether participants or the host, would have been vulnerable to a silent attack that could be carried out with no indication and no interaction from the victim.

Researchers from the digital defense firm A Security say the bug was discovered in early June using publicly available AI models, and that it took fewer than 20 prompts to uncover the vulnerabilities and create a working attack. Zoom issued a security advisory Tuesday, including details about fixes the company has already begun rolling out to address the flaws, which affected devices running all operating systems that Zoom supports—Windows, macOS, Linux, iOS, and Android.

A Security cofounder Omer Gull told WIRED ahead of the disclosure: "What is interesting for us and what we believe is dangerous, is the democratization of these capabilities—the barrier to entry is dropping rapidly. Before, it would have taken a team of five people maybe six months with a lot of refining and iteration to find this. Now people can reach the same results with fewer than 20 prompts. And Zoom is an important type of target because people assume trust when using it. They don't see it as a threat."

The vulnerabilities were found in the protocol used to facilitate real-time annotation during screen sharing. The researchers say that their AI bug hunting systems specifically delved into this component because, like human bug hunters, they have been trained that convoluted and obscure functions often contain overlooked vulnerabilities. This is particularly true with proprietary, closed-source software. An established company like Zoom presumably does extensive code review and vetting on all components and functions, but without the benefit of public, open review, esoteric yet complex features like annotation are more likely to contain mistakes.

Zoom did not respond to multiple requests for comment from WIRED about the A Security findings.

The bugs are now patched, with Zoom issuing both server and client-side fixes—or patches for both Zoom's own servers and the applications that run on customer devices. But the researchers emphasize that it was alarming to contemplate bugs that could have been exploited to take over a target device simply by getting someone onto a Zoom call. Joining a call is in itself a gesture of trust, but given how ubiquitous video calling is in both personal and professional contexts—and given that Zoom in particular is also widely used for events and semipublic activities like webinars—people typically have their guard down when joining a Zoom.

A Security cofounder Yossi Torati told WIRED on a call: "If you just get on a Zoom with us, we can take over your device. The worst-case scenario is that we can take over an enterprise just by having this vulnerability in our hands. If I'm an attacker, I can be on a call with someone from a company, take control of their computer and their credentials, and then use them to move laterally across the enterprise."

Practitioners often call security a "cat-and-mouse game," but as AI bug hunting proliferates, this delicate dance has become an all-out race.

All indications are that the high-tech computer world, at every level from IoT embedded device to consumer PC and the enterprise, is heading for a rough patch. So far, I've been a cheerleader for the "fixing the bugs" team. And the good news has indeed been that astounding number of bugs are rapidly being found and fixed. But that's also the bad news... because the fact that so many latent problems are being found tells us that the software, at every level, that we've been living with for years has been demonstrably riddled with previously unknown flaws.

The best that can be said is that the future remains stubbornly uncertain.

CNBC reports on public valuations following Black Hat

There are some folks who are justifiably profiting from all of this. Last Monday, following the Black Hat conference, CNBC reported:

Cybersecurity stocks CrowdStrike and Palo Alto Networks jumped more than 5% to new highs on Monday on renewed demand for artificial intelligence security tools following the industry's annual Black Hat conference in Las Vegas.

Analysts at BTIG (a large financial services firm) wrote to clients: "The single most consistent theme across our conversations — partners, vendors, and customers alike — was that AI agents have fundamentally changed the threat landscape. While AI agents have become the predominant attack threat and the environment is "meaningfully worse," deployment and AI security tools are only in the "early innings."

Businesses are turning to cybersecurity companies for new agentic tools to fend off adversaries in a hyper-accelerated threat landscape fueled by new cyber models. Executives and potential customers gathered in Las Vegas last week in search of answers and ways to secure systems from rogue AI agents.

BTIG wrote: "We think AI is creating a new modernization cycle in the endpoint security space, which directly benefits CrowdStrike's core business." Analysts at Cantor said: "AI has moved from being a cybersecurity feature to a key pillar of both the attack surface and the attacker/defender infrastructure."

AI Security

As I promised last week, there are two important and fascinating pieces of core AI technology I want to spend some time on today. The first is a solution to what's been dubbed "the dual-use" problem. That's the fancy name given to the fact that most knowledge can be used in ways that we both want and don't want. That's no surprise since that's always been true of knowledge, so what is it about AI that changes this?

Anyone who has spent any time with any of the recent state-of-the-art AI chatbots will have come to appreciate that what we already have today is, at the very least, an over-obliging conversational partner that can barely restrain itself from being oh so very helpful. And that tail wagging puppy happens to also have access to the world's stored knowledge. So, it's not that it was impossible before AI to obtain that knowledge the old fashioned way, you know, by researching, reading, learning and understanding. No. The difference is that friction matters and

AI chatbots have hugely facilitated the access to that same knowledge by nearly eliminating all of the work that was previously required to gain such knowledge. And that's incredibly valuable. That's what underlies all of this frenzied hyper-scaler data center build-out. Investors believe, with good reason, that offering knowledge at our fingertips by phrasing a question is something most of the world will pay for. The fact that AI Chatbots now have just shy of one billion users strongly suggests that these investors are not wrong. I'm completely spoiled. Even though I've never turned any agent loose on anything, Claude is my go-to source for quick answers. It's an accelerator for me. And keep this quiet, but today, I'd pretty much pay anything to have it.

You could own or download the Encyclopedia Britannica or the unabridged Oxford English Dictionary. But you cannot ask either of them questions. It's all just dead knowledge lying there, so it's much less entertaining and fast. That's back to old school researching, reading, learning and understanding. Anyone who has seen a video of this podcast is aware that there's a solid wall of textbooks (and an unabridged Oxford English Dictionary) behind me. I cannot recall the last time I opened any one of them. AI neural network models are our new store of knowledge. Incredible as it may seem — and it would have seemed like science fiction just a few years ago — the collection of such an array of scalar variables, which specify the scaling weights of the inputs to a vast neural network, creates a representation of the expression of all of the knowledge that has been “trained into” that model.

That sentence ended with: *“creates a representation of the **expression** of all of the knowledge that has been “trained into” that model.”* I think it's important to frame it that way. What we're feeding into the neural network while it's being trained is the expression of the knowledge, largely gleaned from the Internet, as well as from reference texts AI companies have been quietly purchasing and ingesting, to create an overall input corpus.

The end result of this — and this is still the mind-boggling bit for me — is purely and simply a next-most-likely-token prediction engine. Leo's initial very early observation was that what we were calling AI was little more than fancy spell check. Then last week we quote a nearly stunned Matthew Green specifically saying that it's not just fancy spell check — but its essence has not changed. Leo was not wrong then and Matthew also not wrong today. So what explains this apparent disparity?

It's that over the past several years what was initially a simple next word predicting “spell check” has become really really really really fancy spell check. Deep underneath even today's astonishing apparently intelligent reasoning systems, down at their core, is still just a neural network that only does exactly one thing: Given a long, and in many cases astonishingly long, token sequence, it predicts the most likely next token. And the fact that we get what we now get from that... is still mind-boggling to me.

I'm going to spend a bit more time on this because a deeper understanding of the truth of what's actually going on with today's AI will help everyone to appreciate the second of the two research papers I plan to share.

Leo's original “it's just spell check autocomplete” summation has its roots in AI circa 2020. Way back then, if you were to carefully phrase a question to GPT-3 such as “The capital of France is?”, it would be able to complete the sentence by emitting the next expected word “Paris” because

the model's vast statistical dataset made that the next most likely word. But using the question-style phrasing: "What is the capital of France?" would not have met with success. So what happened? How did we turn these models from autocomplete engines into conversationalists?

It took a few years of experimentation, but AI researchers first used something that's now known as "instruction tuning". They took the knowledge-trained model and fine-tuned it on a surprisingly small set of human-written examples of what good responses would look like. After that, something known as RLHF — reinforcement learning from human feedback — was used. This applied preference rankings where humans compared and ranked multiple outputs from best to worst. That was used to train a reward, which pushed the model toward that behavior.

But here's the most astonishing part of that: Researchers found that they could employ a comparatively small number of "query / ranked-response" samples, providing reward feedback, and these large language models would, with startling speed, be able to generalize from the language patterns of queries and response across their entire knowledgebase. To better appreciate the scale of this, a model that had been trained on trillions of tokens of raw knowledge — this creating the original statistical autocomplete engine — could then be rewarded using only tens of thousands to low hundreds of thousands of query/response examples, and the behavior of the entire model would be reshaped across all of the knowledge that it contains. The fact that this occurs with such sample efficiency was utterly unexpected. Today it's a real, well-documented phenomenon that's known as the *"superficial alignment hypothesis."* The idea is that all of the raw knowledge was already there from the model's initial knowledge corpus training. Then a relatively miniscule bit of fine-tuning teaches the model format and behavior but not any new knowledge.

Stated a bit differently for clarity, the breakthrough four years ago was not the use of a larger model than we had at the time. That's one of the things that's been happening since then. The breakthrough was the unexpected discovery that a comparatively infinitesimal dose of human-provided *"here's what a good answer looks like, and here's which of these answers is better"* training would reshape a massive already-trained model's entire behavior — turning it from something that completes patterns into something that acts like it's trying to be helpful. So once the massive model learned what "helpful" looked like and that its trainers wanted it to look like that, all of its stored knowledge was immediately available in that new "helpful" format... and we got helpful chatty AI.

As we know, those first steps made by ChatGPT were more than a little shaky. So researchers realized that their newly birthed ChatBot would need some additional post-training *"alignment"* — as it's now being called. This began as the RLHF (Reinforcement Learning from Human Feedback) we talked about before. But then, a year later in 2023, a handful of AI researchers at Stanford University published a paper titled: *"Direct Preference Optimization: Your Language Model is Secretly a Reward Model."* Since all of the descendents of this DPO system (IPO, KTO, ORPO and SimPO) descend from DPO, I'll share the Abstract of the Stanford researcher's original paper. They explain their invention, writing:

While large-scale unsupervised language models (LMs) learn broad world knowledge and some reasoning skills, achieving precise control of their behavior is difficult due to the completely

unsupervised nature of their training. Existing methods for gaining such steerability collect human labels of the relative quality of model generations and fine-tune the unsupervised LM to align with these preferences, often with reinforcement learning from human feedback (RLHF).

However, RLHF is a complex and often unstable procedure, first fitting a reward model that reflects the human preferences, and then fine-tuning the large unsupervised LM using reinforcement learning to maximize this estimated reward without drifting too far from the original model.

In this paper we introduce a new parameterization of the reward model in RLHF that enables extraction of the corresponding optimal policy in closed form, allowing us to solve the standard RLHF problem with only a simple classification loss. The resulting algorithm, which we call Direct Preference Optimization (DPO), is stable, performant, and computationally lightweight, eliminating the need for sampling from the LM during fine-tuning or performing significant hyperparameter tuning.

Our experiments show that DPO can fine-tune LMs to align with human preferences as well as or better than existing methods. Notably, fine-tuning with DPO exceeds PPO-based RLHF in ability to control sentiment of generations, and matches or improves response quality in summarization and single-turn dialogue while being substantially simpler to implement and train.

I wanted to share that because I didn't want to leave everyone with the belief that original RLHF — Reinforcement Learning from Human Feedback — approach which began this transformation was what the industry was still using. It was the genesis. Stanford's DPO — Direct Preference Optimization — dramatically improved upon it, and DPO's success spawned a number of successors which I cited earlier.

So what is all of this about? It's about how we take a massive neural network which has been trained on and contains raw knowledge, which can initially only be used to predict the next most likely token, and impress upon that network actual BEHAVIOR that we want. The first example of behavior was turning the network into something that could actually respond to queries. That gave us the first interactive AI. But as I noted, those first steps were somewhat shaky. So over time, researchers learned that by using the technologies I've just described they could improve the model's instruction following behavior so that it would answer the question that was asked as well as respect the requested format, length and language. The model's style and tone could also be modified to improve its response formatting, structure, hedging, politeness and verbosity. These factors were given significant weight. As we saw in the early days, sycophancy was an often seen problem. This arose because we humans reliably prefer being agreed with, so preference optimization trains models toward agreement, and it takes deliberate counter-effort to prevent it. But that's now in place. Another improvement that was impressed upon models was factuality, preferring responses that admit uncertainty rather than confident fabrication.

The other class of behavior that can be trained into a model is its refusal to provide certain classes of information. It's one thing for a model to contain knowledge that's dual-use which only authorized users should be able to access, but some model behavior and/or knowledge dissemination should be proactively prevented. The test AI designers apply is termed "uplift". Does a model meaningfully advance someone's capability beyond what they could already get? This falls into two categories: Where knowledge **is** the harm and where the output **is** the harm.

Examples of knowledge uplift are bioweapon synthesis routes, nerve agent production and nuclear device design. The relevant literature is scattered, partial, and difficult to assemble. Therefore, any model that would synthesize it into an actionable protocol provides genuine uplift toward mass casualties. And the asymmetry is clean here: defensive work in these fields does not require the synthesis route. A vaccine researcher needs pathogen biology, not an enhancement protocol. This list and these examples will take no one by surprise and they are the one category where essentially every AI model provider refuses regardless of credentials or system prompt.

The other class of model behavior that requires restriction is output which is itself the harm. An example of such, which carries universal condemnation, would be text that sexualizes minors. Models will not produce any such text.

As we've seen earlier, the good news is that these large language models are astonishingly able to absorb and embrace whatever behavioral restrictions we choose to impress upon them. We're able to give them what appears to be a personality, many forms of behavior, and also instruct them what they may and may not do. That's the good news. The bad news is that it turns out that any behavior that can be easily imprinted can also be easily removed.

In the summer of 2024, researchers at ETH Zürich, the University of Maryland, Anthropic and MIT published a paper titled "*Refusal in Language Models Is Mediated by a Single Direction*". The Abstract of their paper employs some inside baseball terminology, but everyone should be able to easily get the gist of it, I'll explain a bit more afterward. Their paper's abstract says:

Conversational large language models are fine-tuned for both instruction-following and safety, resulting in models that obey benign requests but refuse harmful ones. While this refusal behavior is widespread across chat models, its underlying mechanisms remain poorly understood.

*In this work, across 13 popular open-source chat models up to 72B parameters in size, we show that refusal is mediated by a one-dimensional subspace. Specifically, for each model, we find a single **direction** such that erasing this direction from the model's residual stream activations **prevents** it from **refusing** harmful instructions, while adding this direction elicits refusal on even harmless instructions.*

Leveraging this insight, we propose a novel white-box jailbreak method that surgically disables refusal with minimal effect on other capabilities. Finally, we mechanistically analyze how adversarial suffixes suppress propagation of the refusal-mediating direction.

Our findings underscore the brittleness of current safety fine-tuning methods. More broadly, our work showcases how an understanding of model internals can be leveraged to develop practical methods for controlling model behavior.

What this group discovered was that any late-term model behavior imprinting can later be removed from such models. And the way this is done is wonderful and wild: They compare the model's activations on harmful versus harmless prompts, compute the mean difference, then project the weight matrices orthogonal to that direction. This has the effect of cancelling out the training that created the difference in behavior between harmful versus harmless prompts.

After doing that, the model loses the ability to represent, and therefore to execute, its refusal. And what they found was that this was surgical. It specifically disables all 13 different models' refusal, while having minimal effect on other capabilities. From my lay view of this, it appears clear that since little training was required to imprint the original refusal behavior, the impact upon the model was minimal. They discovered how to identify the changes created by that training so that it could be removed.

When you encounter the term "abliberation" this is what is meant. Not "obliteration" but "abliberation". Just to put a final point on it, a Hugging Face blog posting in the summer of 2024 was titled: "*Uncensor any LLM with abliberation*". I'll share just the intro from that posting to give everyone a sense for where that earlier research led. The blog says:

The third generation of Llama models provided fine-tunes (Instruct) versions that excel in understanding and following instructions. However, these models are heavily censored, designed to refuse requests seen as harmful with responses such as "As an AI assistant, I cannot help you." While this safety feature is crucial for preventing misuse, it limits the model's flexibility and responsiveness.

*In this article, we will explore a technique called "abliberation" that can **uncensor** any LLM without retraining. This technique effectively removes the model's built-in refusal mechanism, allowing it to respond to all types of prompts. The code is available on Google Colab and in the LLM Course on GitHub.*

What is abliberation? *Modern LLMs are fine-tuned for safety and instruction-following, meaning they are trained to refuse harmful requests. In their blog post, Arditi et al. have shown that this refusal behavior is mediated by a specific direction in the model's residual stream. If we prevent the model from representing this direction, it loses its ability to refuse requests.*

The Arditi reference is the research I referred to previously which showed the world how to do this. This blog posting on Hugging Face is one artifact of that preceding research and the companion repository on Github contains all of the details:

https://mlabonne.github.io/blog/posts/2024-06-04_Uncensor_any_LLM_with_abliberation.html

As you would expect, this was all tremendously exciting to the world's AI hackers many of whom immediately jumped on any and every published and available open-weight model and happily "abliberated away" any and all perceived and imposed censorship from those models. Those "abliberated" public open-weight models are now all available for use by anyone who can harness them.

So this finally brings us to the first major topic I wanted to discuss today now that we have a much deeper understanding of where these chatbots came from, how they work, how they can have behavior imprinted upon them after they've been filled with raw knowledge, and how, unfortunately brittle that imprinting is. I should mention that the term "pretraining" is what the AI industry has unfortunately landed on to actually mean the training that occurs before the post-training. I suppose, since there is now always going to be a definite post-training phase — during which behavior is layered on top of the previously trained-in knowledge — if that "pretraining" were just called "training" then it might be assumed to encompass both training

and post-training. So my point is, there's pretraining and post-training and no just plain training in the middle. So now that we know that pretraining is the initial knowledge corpus training phase, I can explain that a small competent team of AI researchers called AE Studio worked with Anthropic to prove the feasibility of a new form of AI model pretraining.

Last month, both AE Studio and Anthropic blogged about it and they published a joint research paper. I'll start by sharing Anthropic's press-release style posting since it provides the essence of the research without dragging us too far down into the weeds. Under the title "*An off switch for dual-use knowledge in AI models*", they wrote:

This post describes research conducted by AE Studio in collaboration with Anthropic.

A frontier AI model is, among other things, a large store of knowledge. Some of that knowledge is dual use, meaning it can be used for good or for bad. For example, knowledge of cybersecurity can help patch critical security vulnerabilities, or it can be used to exploit them. Knowledge of virology can help a researcher create a vaccine, but it can also help a malicious actor design a deadly pathogen. Ideally, we would be able to balance three separate goals: first, limiting access to dual-use capabilities in as surgical a way as possible; second, allowing trusted users to access those same capabilities for beneficial purposes; and third, doing all this without affecting the model's performance on any other task.

Current safeguards are imperfect. We train models to refuse harmful requests and use classifiers to screen inputs and outputs for dangerous content. These layers of protection guard against dangerous outputs—but they don't change the knowledge stored in the underlying model. Despite our safeguards, a sufficiently determined attacker may still try to jailbreak the model, working past its defenses to access the dual-use knowledge.

A more robust protection against misuse would be to control what the model knows. We've explored this before: In earlier work, we filtered information about chemical, biological, radiological, and nuclear weapons out of pretraining data, and later showed that dual-use knowledge can be confined to a removable slice of a model's weights. But filtering is a blunt instrument. It produces one model with one fixed set of capabilities. Using filtering, if you want a model version that can discuss advanced virology—for deployment in a vetted biosecurity lab, say—and another version that can't, you have to train two separate models. Especially in the case of frontier models (which are large and very expensive to train), the cost to the developer would be prohibitive.

I'll interrupt to add that while OpenAI and Anthropic are not being forthcoming about the cost to train a current frontier model, once those two are publicly traded their accounting ledgers will no longer be private. So we will eventually find out just how much these latest models cost to create. However, to get some sense of scale, OpenAI's Sam Altman has stated that the training cost for GPT-4 was more than \$100 million and OpenAI reportedly spent \$3 billion overall on compute to train their models two years ago, in 2024. As we know, models have grown much larger recently. Those numbers ring true since Google's "Gemini" model is believed to have cost \$192 million. So we're talking several, and perhaps many, hundreds of millions of dollars for a training run.

Therefore, the quite valid point Anthropic is making here is that it's massively infeasible to train a state of the art model on pre-filtered knowledge — if you're going to be spending that kind of money on training, the model needs to know everything so that it can have the widest range of use and application. If a state of the art model were to be trained on a filtered subset of everything you wind up with a very expensive and forever limited model.

For example, all cyber-security knowledge were removed from its training corpus before it was trained, the good news is that model would contain no knowledge whatsoever of cyber-security. So on the upside, it would be impossible to spoof or trick or hack or abuse that model in any way to cause it to reveal anything about cyber-security. No AI can share anything that it truly has no knowledge of. So that would be great. But on the other hand, that ultra-expensive model would have absolutely no knowledge relating to cyber-security, which would render it completely useless for defensive security or vulnerability discovery and remediation.

We've seen that imposing post-training behavioral restrictions on open source models whose network weights can be altered was a short-lived solution at best. The means for removing those restrictions is now child's play. And even the best closed-weight models operated by cloud-based hyperscaling providers such as OpenAI and Anthropic have repeatedly been shown to be subject to trickery and abuse (more on how that occurs will be the topic we tackle next).

What's needed is a new solution, which is what these researchers have found. Anthropic continues, writing:

In new research carried out with collaborators at AE Studio, we explore a new method that could enable the benefits of training many separately filtered models, but at the cost of training only one model.

If you're not sure you heard that right, let me repeat it. Anthropic wrote:

In new research carried out with collaborators at AE Studio, we explore a new method that could enable the benefits of training many separately filtered models, but at the cost of training only one model.

We call it GRAM, for Gradient-Routed Auxiliary Modules. Note that the results of the experiments presented here are preliminary—GRAM has not been applied to any of the production models at Anthropic, and we're not sure it ever will be.

I take this to reflect a reasonable and very cautious approach because can you imagine the cost of a mistake... if one of these companies GRAM-trained a model that turned out to have unsuspected problems? There's no reason to believe that's the case, but, again, their caution is understandable. They write:

How GRAM works: *The idea behind GRAM is to give a model dedicated, removable compartments for each category of dual-use knowledge, and to update only those compartments when learning from dual-use data.*

Concretely, GRAM adds extra neurons to every layer of a standard Transformer (the neural network architecture on which large language models are based). These neurons are divided into groups (or "modules"), one module per dual-use category. During training, when the model encounters general-purpose text, it learns in the usual way. But when it encounters text from a dual-use category—virology, for instance—the rules change: the model can use its general knowledge to make predictions, but only the virology module is allowed to learn from that text. The general-purpose weights are temporarily frozen.

The consequence is that virology knowledge accumulates in the virology module rather than diffusing across the whole network. After training, the module can simply be deleted, and the virology knowledge goes with it. Or it can be left in place for trusted deployments, when virology knowledge is needed. The knowledge can be tailored very specifically to the type of deployment needed: in our experiments, we defined four dual-use categories, so that one training run with GRAM yielded a model that can be configured 16 different ways ("on" or "off" for each of the four categories).

We tested GRAM in three settings of increasing realism.

First, on a synthetic dataset of children's stories tagged by topic, a small GRAM model could be reconfigured to "forget" any chosen topic, and each configuration performed almost identically to a separate model trained from scratch with that topic filtered out. That is, for the cost of training a single model, we achieved results that would normally require multiple training runs on different datasets.

Second, we trained a larger model on a realistic mix of web text, code, and scientific papers, with four dual-use domains: virology, cybersecurity, nuclear physics, and a niche programming language (to serve as a proxy for specialized dual-use code). The capability associated with each dual-use domain is routed to its own module. Deleting a module removed the corresponding capability about as effectively as never having trained on that data at all. Remarkably, we find that this removal did not degrade general performance.

We also tested whether an attacker could recover the removed knowledge by training on a small amount of malicious data; GRAM resisted this about as well as data filtering did. By contrast, an "unlearning" technique applied after training only suppressed the knowledge—it was easy to restore with a small amount of fine-tuning.

Third, we ran the experiment at seven model sizes from 50 million to 5 billion parameters. GRAM matched the performance of data filtering at every size, and the gap between "module on" and "module off" grew wider as models got larger.

Let me pause to focus upon that for a moment. The larger the model the more general knowledge was stored outside of the various subject matter specific modules, so the subsequent removal or suppression of any one or more of them during inference had diminishing effects upon the overall model's performance. This is exactly what we would hope to see. They continue, writing:

As AI companies train more capable models, the need to limit access to dual-use capabilities will increase.

In other words, Anthropic understands that the more capable the industry's models become, the more valuable the knowledge they contain will become and thus the need to manage the access to that knowledge grows more crucial. They also make another very good point:

Today, companies limit access through classifiers and refusal training. However, these safeguards are difficult to make robust without degrading performance on harmless requests. Methods like GRAM offer a potential path toward access control that is more robust.

That's a really great point. The current system which combines the refusal training we examined earlier, with real-time input and output classifiers provides at best fuzzy filtering. The AI can frustrate its innocent user by refusing a benign prompt and it can delight a malicious user by letting down its guard when it should not. By using a method like GRAM, a model can have its functioning knowledgebase selectively tuned to the authenticated prompter's access permissions. That's a significant improvement over today's soft and somewhat ad hoc solutions.

Anthropic concludes:

This is early research, and there are clear limitations. We haven't tested GRAM at frontier scale or in a production training pipeline. (As noted above, it has not been applied to any of our Claude models.) Our evaluations quantify performance in terms of next-token prediction ability, rather than performance on real downstream tasks. And there's a deeper open problem that applies to data filtering and methods like GRAM: some dual-use capabilities might be so entangled with general knowledge that no method can separate them cleanly. For further details on our experiments, read the post on our Alignment Science blog.

When I wrote about GRAM two weeks ago in the Security Now! weekend special email before Black Hat, several of our listeners wrote back with feedback that I shared during our Black Hat podcast. Their concerns surrounded worries over censorship and "who gets to decide who has access to what data." During Black Hat, both Richard and Paul chimed in immediately that this was just a different version of the way things have always been. The fact that AI has made most of the world's knowledge vastly more accessible doesn't necessarily mean that AI has made ALL of the world's knowledge vastly more accessible to everyone. There isn't any entitlement to the knowledge an AI holds. After all, it cost those companies many hundreds of million of dollars to create and offer that facility. I would argue that they can put whatever restrictions on it they wish. If commercial providers of that knowledge are required by internal policy, public pressure, the government, their stockholders, or whomever, to gate and control access to some aspects of that knowledge, then I would argue that the commercial providers have every right to do so.

We just saw an example with the OpenAI / Hugging Face "incident" where Hugging Face was unable to deploy either Anthropic's or OpenAI's models to help with their cyber-security forensic investigation because Hugging Face hadn't been granted the magic keys to those AI's cyber-security knowledge. Everyone would argue that they should have had such access, and we later heard that OpenAI would be giving it to them.

I kept repeating the qualifier "commercial providers" because there are alternatives, and an alternative is exactly what Hugging Face turned to after the commercial models refused to help. They used one of the many publicly available completely unrestricted open-source models.

So anyone who might object to the big commercial services restricting what can be done can easily turn to any of the many alternatives. Given what I was able to do with the fully unrestricted and uncensored [Venice.AI](#) service, which I played with briefly when it appeared and we talked about it here, I'm pretty certain that fully unrestricted, unrestrained and uncensored AI models are readily available.

So. We've run out of time and there was a lot to take in. We have a far better understanding of the way today's AI works and of the problems it faces in the world. Next week we're going to tackle that second topic, which demonstrates the staggering lack of true control that AI providers have over their models. We're going to learn how and why prompt injection attacks continue despite the best minds in the industry struggling to prevent them.

As I said last week, stay tuned!

